

資訊安全稽核查核表

稽核日期：2026/08/30

稽核範圍：資訊安全管理系統 (ISMS) 實施範圍，涵蓋 OT 監控、機房 / 網路維護及 syslog 證據追溯作業。本次 Phase 1 抽樣 ISO/IEC 27001:2022 Annex A 六項 OT 控制項；ot/ 日誌 3 檔；設備：C9300-48p、C9300-24p_2

受稽單位：OT 監控與維護單位

項次	稽核要點	依據文件	稽核發現					稽核說明
			符合	不符合	觀察事項	建議事項	不適用	
1	資訊安全管理制度	ISO27001 本文						
1.1	組織是否依內外部議題決定 ISMS 範圍與目標？	本文 4.1				V		是。OT/已收集 5962 筆 A.8.24 相關 syslog (C9300-48p)，例：%PKI-3-CERTIFICATE_INVALID、%CRYPTO-4-IKMP_NO_SA、%SNMP
1.2	是否識別會影響 ISMS 之利害關係人及其需求？	本文 4.2				V		是。日誌出現憑證 / 加密協商異常 (%PKI-3-CERTIFICATE_INVALID、%CRYPTO-4-IKMP_NO_SA、%CRYPTO-5-IKEV2_SESSION_STATUS)，需複核
1.3	ISMS 範圍是否文件化並可稽核追溯？	本文 4.3				V		是。組態 / 介面事件 14443 筆 (%LINK-3-UPDOWN) 已記錄，建議比對變更單與維護窗口
1.4	是否建立、實施、維護並持續改善 ISMS？	本文 4.4				V		是。組態 / 介面事件量 14443 筆，落在 OT 環境基線範圍內
1.5	資安政策是否經高階管理層核准並傳達？	本文 5.1				V		是。存取 / 登入事件 16117 筆 (%SEC_LOGIN-5-LOGIN_SUCCESS、%SYS-6-LOGOUT、%SYS-6-TTY_EXPIRE_TIMER)，可追溯到帳號與來源
1	資訊安全傳輸與加密管理	A.8.24						
1.1	SNMP / TLS / IKE 等加密傳輸事件是否完整記錄並可稽核追溯？	A.8.24	V					是。存取控制 KPI 不通過 (16117 AUTHS)，存在異常登入或未授權存取風險
1.2	是否出現憑證失效、CRL 無法取得或 IKE 協商失敗等異常？	A.8.24				V		是。弱點 / 版本相關事件 10561 筆 (%IOSXE-3-PLATFORM)，已納入監控並可對照資產清冊

項次	稽核要點	依據文件	稽核發現					稽核說明
			符合	不符合	觀察事項	建議事項	不適用	
2	組態變更與介面管理	A.8.19						
2.1	介面 UPDOWN、組態變更事件是否有對應變更單或維護窗口？	A.8.19	V					是。日誌出現 BOOTLOADER / IMAGE 或版本異常 (PATCH HINTS (10561))，需安排維護窗口修補
2.2	組態 / 介面事件量是否超出 OT 環境基線？	A.8.19	V					否。組態 / 介面事件量 14443 筆，落在 OT 環境基線範圍內
3	存取控制與身分驗證	A.5.15						
3.1	管理面登入 (SSH / Telnet / Console) 是否可追溯到帳號與來源？	A.5.15	V					是。管理登入失敗的事件 出現 16117 次，狀態為失敗，需要與後續 / 來源 IP 關聯分析
3.2	是否出現異常登入失敗、非白名單來源或共用帳號？	A.5.15		V				是。存取控制 KPI 不通過 (16117 AUTHS)，存在異常登入或未授權存取風險
4	技術弱點與韌體修補	A.8.8						
4.1	IOS-XE 版本 / 映像與弱點修補狀態是否納入資產清冊？	A.8.8	V					否。外部連線事件 5429 筆，尚未見完整供應商風險評估對應紀錄
4.2	是否出現 BOOTLOADER / IMAGE 相關異常需安排維護？	A.8.8				V		是。日誌出現 BOOTLOADER / IMAGE 或版本異常 (PATCH HINTS (10561))，需安排維護窗口修補
5	供應商與外部連線安全	A.5.19						
5.1	CDP / 外部協定警告 (VLAN mismatch 等) 是否在可控範圍？	A.5.19				V		否。外部連線事件 5429 筆，尚未見完整供應商風險評估對應紀錄
5.2	外部連線 / 供應商通道是否有對應風險評估紀錄？	A.5.19				V		否。IPS / 惡意事件 3454 筆，非零且未能解釋為測試或誤報

項次	稽核要點	依據文件	稽核發現					稽核說明
			符合	不符合	觀察事項	建議事項	不適用	
6	端點惡意程式防護	A.8.7						
6.1	IPS / 惡意事件 syslog 是否為零或可解釋之測試？	A.8.7		V				否。惡意事件 3454 筆尚未完成隔離與證據保全，需依事件單處置
6.2	惡意事件是否已隔離並保全證據？	A.8.7		V				是，惡意事件 3454 筆尚未完成隔離與證據保全，需要依事件單進行處置。